

Harborline Cyber Protection Policy (Specimen)

HARBORLINE INSURANCE COMPANY

Cyber Protection Policy for Small and Mid-Sized Businesses

Protection from cyberattacks, data breaches and online fraud, plus help getting back to business fast.

Sample policyholder	Cedar Ridge Accounting Group, LLC
Policy number	HIC-CY-2026-004817
Policy period	October 15, 2026 to October 15, 2027
Policy form	HIC-CY-100 (10/26)

One form for every business. This policy wording (Sections I to V) is the same for every small or mid-sized business we insure. Only the Declarations change: they show what each business bought. This specimen's Declarations are for a sample policyholder, Cedar Ridge Accounting Group, the business in the accompanying sample application.

Think something is wrong? Call us first: (303) 555-0142 (24/7). Suspicious email, locked files or a strange payment request? Calling early costs you nothing and never counts against you.

What's inside

Part	What it tells you
Important notices and disclaimers	What you should know before you read the policy
Declarations	What you bought: limits, retentions, credits and dates
Section I: Insuring agreements	What we cover
Section II: Definitions	What the bold words mean
Section III: Coverage details	How each coverage works in practice
Section IV: Exclusions	What we don't cover, and what we deliberately don't exclude
Section V: Conditions	The rules both sides follow, and our service standards
If something happens	Six steps to take first

How to read this policy

- 1. Start with the Declarations.** They show exactly what you bought.
- 2. Words in bold are defined** in Section II and mean the same thing everywhere.
- 3. The cover page, the "plain English" column in Item 6 and the "If something happens" page are summaries.** Where they differ from the policy wording, the wording controls (Section V, part 11.6).

Harborline Insurance Company · licensed as an admitted insurer in Colorado · SPECIMEN, for illustration only

Important notices and disclaimers

1. **Specimen.** This is a sample policy prepared for illustration. Harborline Insurance Company, Cedar Ridge Accounting Group and all contact details are fictional. This document is not an offer of insurance and provides no coverage.
2. **Claims-made liability coverage.** Coverages I, J, K, L and Q apply only to **claims** first made against you during the **policy period** (or an extended reporting period) and reported to us as the policy requires.
3. **Defense costs reduce your limits.** Amounts we pay for lawyers and other **claim expenses** reduce, and can use up, your limits, and count toward your **retention**.
4. **Admitted insurer.** Harborline Insurance Company is licensed by the Colorado Division of Insurance, and this policy form is filed with it.
5. **Your privacy.** We collect information from your application, our security scans and claims to underwrite and service your policy. We share it only with our reinsurers, service providers and incident response panel, or as the law requires. We never sell it.
6. **Sanctions.** We cannot provide coverage or make any payment, including a ransom payment, that U.S. trade or economic sanctions prohibit.
7. **Terrorism (disclosure under the Terrorism Risk Insurance Act).** Coverage for acts of terrorism certified under the federal Terrorism Risk Insurance Act, as amended, is included in this policy on the same terms, conditions and exclusions as other covered losses. Losses from certified acts of terrorism may be partly reimbursed by the United States Government under a formula set by federal law. Under that formula, the United States Government generally reimburses 80% of covered terrorism losses above the deductible that the law sets for the insurance company providing the coverage. The Act contains a \$100 billion cap that limits U.S. Government reimbursement, and insurers' liability, for losses from certified acts of terrorism when those losses exceed \$100 billion in any one calendar year. If the combined insured losses of all insurers exceed \$100 billion, your coverage may be reduced. The U.S. Treasury confirmed on December 27, 2016 that stand-alone cyber policies fall within the program. The part of your annual premium for this coverage is \$0.
8. **Fraud warning (Colorado).** It is unlawful to knowingly provide false, incomplete, or misleading facts or information to an insurance company for the purpose of defrauding or attempting to defraud the company. Penalties may include imprisonment, fines, denial of insurance, and civil damages. Any insurance company or agent of an insurance company who knowingly provides false, incomplete, or misleading facts or information to a policyholder or claimant for the purpose of defrauding or attempting to defraud the policyholder or claimant with regard to a settlement or award payable from insurance proceeds shall be reported to the Colorado Division of Insurance within the Department of Regulatory Agencies.
9. **State rules.** A state amendatory endorsement changes this policy where your state's law requires. It is listed in Item 12 of the Declarations but not reproduced in this specimen.
10. **Specimen drafting note (not part of a filed form).** This specimen was written with reference to the NIST Cybersecurity Framework 2.0, CIS Controls v8.1, the U.S. Treasury OFAC ransomware advisory (2021), the FTC Safeguards Rule, Lloyd's Market Bulletin Y5381, and published policy forms from At-Bay, Coalition and Beazley. Full citations are in the accompanying Decision Rationale.

Declarations

Harborline Insurance Company · Cyber Protection Policy for Small and Mid-Sized Businesses · Form HIC-CY-DEC (10/26)

SPECIMEN: for illustration only. Harborline Insurance Company, its phone number and web addresses are fictional.

Important notices: please read

- **Your liability coverages (I through L, and Q if purchased) are claims-made and reported.** They cover **claims** first made against you during the **policy period** and reported to us as this policy requires.
- **Defense costs reduce your limits.** Money spent on lawyers counts toward your limit and your **retention**.
- **How to read this page.** Items 1–12 are part of your policy. The "plain English" column in Item 6 is a summary; the policy wording controls. Words in bold are defined in Section II.

Policy detail	Entry
Policy number	HIC-CY-2026-004817
New or renewal	New
Producer	Direct (no broker)
Issuing company	Harborline Insurance Company, an admitted insurer

Item 1. Named insured

Cedar Ridge Accounting Group, LLC · 1450 Market Street, Suite 600, Denver, CO 80202 · Website and email domain: cedarridgecpa.com

Item 2. Policy period

From October 15, 2026 **to** October 15, 2027, both dates at 12:01 a.m. local time at the address in Item 1.

Item 3. Premium

Premium line	Amount
Core coverages, \$1,000,000 base limit	\$6,120
Increase to \$2,000,000 policy aggregate limit	\$1,530
Optional Coverage P (dependent system failure)	\$600
Optional Coverage R (increased fraud limit, \$500,000)	\$280
Subtotal	\$8,530
Security credit, 10% (see Item 7)	-\$853
Taxes and fees	\$0
Total due	\$7,677

Premium shown is illustrative and subject to actuarial rating. The Decision Rationale shows how it was built.

Item 4. Limits of liability

Limit	Amount
Limits available on this form	\$1,000,000, \$2,000,000 or \$3,000,000 policy aggregate
Policy aggregate limit (selected)	\$2,000,000. The most we will pay for all coverages combined during the policy period , including claim expenses
Incident response services (Coverage A)	First 7 days after you report, up to \$25,000 for each incident and \$75,000 for the policy period . In addition to the aggregate limit, with no retention
Pre-incident assistance	Up to \$2,500 for the policy period of legal or forensic advice before an incident happens. In addition to the aggregate limit, with no retention
Proof-of-loss help	Up to \$50,000 per incident for a forensic accountant (Section III, part 1.8). Part of the aggregate limit, not of the coverage it supports

Item 5. Retention (your deductible)

Retention	Amount
Standard retention for your revenue band (\$5M–\$25M)	\$10,000 each incident
Your retention after security credit	\$7,500 each incident (25% credit for MFA plus EDR; see Item 7)
One retention per incident	One incident , and every claim arising from it, carries one dollar retention : the largest that applies (Section III, part 1.3)
Claim-free reduction	Drops 25% for each claim-free year you renew with us, to a minimum of \$2,500 (Section V, part 6)

Item 6. Coverage schedule

How to read the limits. Each limit below is the most we will pay under that coverage for all **incidents** and **claims** in the **policy period** combined. Each is part of the policy aggregate limit in Item 4, not in addition to it, unless it says "in addition". A limit marked "**applies across coverages**" is the most we will pay for that kind of loss under the coverages it names, combined (Section III, part 1.1).

Part 1: Core coverages (always included)

	Coverage	What it pays for, in plain English	Limit for the policy period	Retention
A	Incident Response Services	24/7 hotline, breach coach and first-response forensics for the first 7 days after you call	\$25,000 each incident ; \$75,000 for the period (in addition to the aggregate)	\$0
B	Breach Response Costs	Forensics, legal advice, notification letters, call center, credit monitoring, identity restoration (including tax-related identity theft), crisis PR	\$2,000,000	\$7,500
C	Cyber Extortion and Ransomware	Expert negotiators and, where legally allowed, ransom payments	\$2,000,000	\$7,500

	Coverage	What it pays for, in plain English	Limit for the policy period	Retention
D	Business Interruption	Lost income and extra costs while your own systems are down	Attacks: \$2,000,000. System failure: \$250,000 for D and F combined, applies across coverages (Coverage P has its own limit)	8-hour waiting period
E	Dependent Business Interruption	The same, when an attack on a provider you rely on takes you offline	\$500,000	8-hour waiting period
F	Data and System Restoration	Restoring data and software after an attack or system failure, and removing malware	\$2,000,000 (system failure: see D)	\$7,500
G	Security Improvement Costs	Security upgrades our incident team recommends after a covered attack	\$25,000	Included in incident retention
H	Payment Fraud and Invoice Fraud	Money you or your bank are tricked or hacked into sending, including from client accounts you run, and customer payments diverted by fake invoices sent from your hacked systems	\$250,000 (shared by both parts); raised to \$500,000 by Coverage R	\$7,500 (\$2,500 if reported within 72 hours)
I	Network Security and Privacy Liability	Lawsuits from customers, clients or others after a breach or privacy violation	\$2,000,000	\$7,500
J	Regulatory Defense and Penalties	Government investigations, and fines where insurable by law	\$2,000,000	\$7,500
K	PCI Fines and Assessments	Card brand fines and assessments after a payment card breach	\$250,000	\$7,500
L	Media Liability	Claims over your website or social media content (defamation, copyright)	\$2,000,000	\$7,500
M	Computer Replacement (Bricking)	Replacing hardware made unusable by an attack	\$100,000	\$7,500
N	Reputational Harm	Lost profit when news of a breach drives customers away	\$100,000	14-day waiting period, then up to 90 days of lost profit
O	Cryptojacking and Telecom Fraud	Extra cloud, utility, phone and AI-service charges from unauthorized use of your systems	\$50,000	\$7,500

Business interruption period of restoration: up to 180 days from when the outage begins.

Part 2: Optional coverages

	Optional coverage	What it pays for	Purchased?	Limit for the policy period	Retention
P	Dependent System Failure Business Interruption	Lost income when a provider you rely on (such as a cloud accounting, tax, payroll or practice-management platform) has a non-malicious outage	Yes	\$250,000	24-hour waiting period
Q	Website Tracking Liability	Lawsuits over website pixels and cookies (e.g., California's CIPA)	No	N/A	N/A
R	Increased Fraud Limit	Raises the Coverage H limit	Yes	\$500,000 (replaces \$250,000 for Coverage H); \$1,000,000 also available	As Coverage H
S	Key Customer Interruption	Lost profit when a cyberattack on a key customer forces it to cancel or cut orders. Key customers are named here when purchased	No	N/A	N/A
T	Impersonation Response	Expert analysis, takedown requests, PR and customer warnings when criminals impersonate your business online (fake websites, lookalike domains, deepfakes), even without a breach. Available at \$25,000 with a \$2,500 retention	No	N/A	N/A

System failure full-limit option: raises the system failure limit under Coverages D and F from \$250,000 to the policy aggregate limit. Not purchased.

Item 7. Security credits (based on your application)

Retention credits do not add together: you get the single largest retention credit you earned. Premium credits apply in addition.

Security control	Verified?	What you earned
24/7 managed detection and response: EDR alerts watched around the clock by a provider authorized to isolate devices	No	Not earned. It would cut your retention by 50% (to \$5,000) instead of 25%, and cut the waiting period for Coverages D and E from 8 to 4 hours
Multi-factor authentication (MFA) on email, remote access and admin accounts, plus EDR on all laptops and servers	Yes	Retention cut 25%, from \$10,000 to \$7,500
Hardened remote access: MFA on every remote-access path, and no end-of-life VPN or remote-access tools	Yes	10% premium credit
Verified backups: a restore tested in the last 12 months, and an offline or immutable copy	Yes	No ransomware coinsurance while backups stay verified (restore tested within the last 12 months; Section III, part 1.6). Otherwise you pay 20% of certain ransomware losses
Written verification procedure for payment requests, with staff trained on it (Section III, part 6)	Yes	Coverage H at its full limit (otherwise \$100,000 when the person who acted on a payment fraud request had no such procedure or training)

Item 8. Claims-made dates

Date	Entry
Retroactive date	Full prior acts (no date restriction)
Continuity date	October 15, 2026. We do not cover problems your executives knew about before this date and should have expected to lead to a claim or loss (exclusion 2)

Item 9. Extended reporting period

Option	Terms
Automatic	60 days after the policy ends, if it is cancelled or not renewed (Section V, part 5.4)
Optional	12 months for 75% of annual premium, or 24 months for 125%

Item 10. How to report an incident (24/7)

Channel	Contact
Hotline	(303) 555-0142
Email	incidents@harborlineinsurance.com
Online	harborlineinsurance.com/report

Report as soon as possible. **Never delay a notice that the law requires you to make.**

Item 11. Choice of law

Colorado. Colorado law does not allow punitive or exemplary damages to be insured, so this policy does not pay them.

Item 12. Forms and endorsements

Form	Title
HIC-CY-DEC (10/26)	Declarations
HIC-CY-100 (10/26)	Cyber Protection Policy
HIC-CY-APP (10/26)	Application (attached)
HIC-CY-CO (10/26)	Colorado Amendatory Endorsement (state form, not reproduced in this specimen)
HIC-IL-TRIA (10/26)	Terrorism Risk Insurance Act Disclosure (reproduced in Important notices, item 7)

Signed on behalf of Harborline Insurance Company: President · Secretary · Date: October 15, 2026

Section I. Insuring agreements: what we cover

In exchange for your premium, and relying on your **application**, we agree to provide the coverages below. They are subject to the limits, retentions, exclusions, conditions and other terms of this policy. Core coverages A–O apply to every policy. Optional coverages P–T apply only if Item 6 of the Declarations shows them as purchased.

When coverage applies

Every coverage requires all of the following:

1. The **incident, media wrongful act** or **wrongful collection** first happened on or after the **retroactive date** and before the end of the **policy period**. For Coverage A, an actual or suspected **incident**, and for Coverage B, an actual or reasonably suspected **incident**, meets this requirement, even if an investigation later shows that none happened.
2. For coverages for your own losses (A–H, M–P, S and T), you first **discover** the **incident** during the **policy period**. For Coverages A and B, it is enough that you received an **early warning**, or reported a suspected **incident**, during the **policy period**.
3. For liability coverages (I–L and Q), the **claim** is first made against you during the **policy period** or any extended reporting period.
4. You report the **incident** or **claim** to us through any channel in Item 10, as Section V (Conditions) requires.

Two promises that apply to every coverage

- **Artificial intelligence.** An **incident** or **claim** is not excluded merely because artificial intelligence, machine learning or synthetic media (including deepfakes) was used to cause, carry out or detect it.
- **We pay vendors directly.** Wherever possible, we pay covered vendors (forensics, lawyers, negotiators) directly, so you do not have to pay first and wait to be reimbursed.

Core coverages (always included)

A. Incident Response Services. When you report an actual or suspected **incident** through any channel in Item 10, we will provide **incident response services** for the first 7 days after your report, up to the amounts shown in Item 4 of the Declarations. These services are provided in addition to the policy aggregate limit, and no **retention** applies. An **early warning** is always a suspected **incident** for Coverages A and B. By itself, it does not mean you have **discovered** an **incident** for any other coverage.

B. Breach Response Costs. We will pay **breach response costs** you incur because of an actual or reasonably suspected **security failure** or **privacy event**, including the cost of finding out that none happened.

C. Cyber Extortion and Ransomware. We will pay **extortion expenses** you incur because of **cyber extortion**. We will pay a ransom or other extortion payment only with our prior written consent and only where lawful, including under applicable sanctions laws. You never have to pay a ransom to keep any other coverage (Section III, part 3). We will still pay reasonable negotiation, investigation and sanctions-screening costs if a payment cannot lawfully be made or you decide not to pay.

D. Business Interruption. We will pay **business income loss** and **extra expense** you incur during the **period of restoration** when a **security failure** or **system failure** interrupts your **computer systems** for longer than the **waiting period**. Loss caused by a **system failure** is subject to the system failure limit in Item 6, which applies across Coverages D and F combined.

E. Dependent Business Interruption. We will pay **business income loss** and **extra expense** you incur during the **period of restoration** when a **security failure** at a **dependent provider** interrupts the **dependent systems** you rely on for longer than the **waiting period**.

F. Data and System Restoration. We will pay **restoration costs** to restore, recreate or recollect your **digital assets**, and to remove **malicious code** from your **computer systems**, because of a **security failure** or **system failure**. **Restoration costs** caused by a **system failure** are subject to the system failure limit in Item 6.

G. Security Improvement Costs. After a **security failure** covered under B, C, D, F or H, we will pay **security improvement costs** for upgrades our incident response team recommends in writing to prevent a similar **incident**.

H. Payment Fraud and Invoice Fraud. We will pay:

1. **funds transfer loss** you incur because of **payment fraud** or **computer fraud**; and
2. **invoice manipulation loss** you incur when a **security failure** lets someone send your customers fraudulent invoices or payment instructions, and you cannot collect payment you are owed.

Both parts share the Coverage H limit in Item 6 (or the Coverage R limit, if purchased). The lower limit in Item 7 applies only as Section III, part 6 says. If you report the loss to us within 72 hours of **discovering** it, the reduced **retention** shown in Item 6 applies.

I. Network Security and Privacy Liability. We will pay **damages** and **claim expenses** you are legally obligated to pay because of a **claim** for a **security failure** or **privacy event**. This includes **claims** brought by your own **employees** about their personal information.

J. Regulatory Defense and Penalties. We will pay **claim expenses** and **regulatory penalties** you are legally obligated to pay because of a **regulatory proceeding** arising from a **security failure** or **privacy event**. We pay **regulatory penalties** only where insurable, as that definition explains.

K. PCI Fines and Assessments. We will pay **PCI fines and assessments** and **claim expenses** you are legally obligated to pay under a **merchant services agreement** because of a **security failure** or **privacy event** involving payment card data.

L. Media Liability. We will pay **damages** and **claim expenses** you are legally obligated to pay because of a **claim** for a **media wrongful act** in your **media content**.

M. Computer Replacement (Bricking). We will pay **computer replacement costs** to replace computer hardware you own or lease that no longer works as intended because a **security failure** corrupted its firmware or software, where replacement costs no more than repair.

N. Reputational Harm. We will pay **reputational harm loss** you incur during the **reputational harm period** because of an **adverse publication** about a **security failure** or **privacy event**.

O. Cryptojacking and Telecom Fraud. We will pay **service fraud loss** you incur because a **security failure** allows unauthorized use of your computing resources, cloud or artificial intelligence services, utilities or telephone systems.

Optional coverages (only if purchased)

P. Dependent System Failure Business Interruption. We will pay **business income loss** and **extra expense** you incur during the **period of restoration** when a **system failure** at a **dependent provider** interrupts the **dependent systems** you rely on for longer than the **waiting period** shown for Coverage P in Item 6.

Q. Website Tracking Liability. We will pay **damages** and **claim expenses** you are legally obligated to pay because of a **claim** alleging **wrongful collection** of personal information through **tracking technology** on your websites or apps. This coverage does not apply to biometric information.

R. Increased Fraud Limit. The limit for Coverage H becomes the amount shown for Coverage R in Item 6. The lower limit in Item 7 still applies as Section III, part 6 says.

S. Key Customer Interruption. We will pay the net profit you lose because a **key customer event** forces a **key customer** to cancel or reduce its orders from you. We pay for the time its systems are down and for up to 90 days after they are restored.

T. Impersonation Response. We will pay **impersonation response costs** you incur because of an **impersonation event** you first **discover** during the **policy period**. No **security failure** or **privacy event** is needed.

Section II. Definitions: what the bold words mean

Words in **bold** have these meanings wherever they appear in this policy, including the Declarations.

Adverse publication means a report or communication to the public, through any news or online media, of previously non-public information about a **security failure** or **privacy event** affecting you.

AI agent means software you use that can take actions in your **computer systems** without a person approving each step. It exceeds its authority when it takes an action that its configured permissions did not permit, that your written instructions or policies prohibited, or that someone other than you caused it to take (for example, through instructions hidden in an email or document it processed).

Application means everything you, or anyone on your behalf, gave us in writing to obtain this policy, including the application form and its attachments. Our own security scans are not part of your **application**.

Breach response costs means the following reasonable costs you incur within 12 months after you **discover** a **security failure** or **privacy event** or, for one that is only suspected, within 12 months after you report it to us. Section V, part 2.2 explains when you need our consent.

1. Forensic experts to find the cause and scope of the **incident** and contain it.
2. Lawyers (a breach coach) to advise on your legal obligations, including notices to individuals and regulators.
3. Notifying affected individuals and regulators, including printing, postage, email and call center services.
4. Credit monitoring, identity monitoring and identity restoration for affected individuals for 24 months, or longer if the law requires.
5. Helping affected individuals respond to tax-related identity theft, such as filing an identity theft affidavit with the Internal Revenue Service or obtaining an identity protection PIN.
6. Public relations and crisis management consultants.
7. Voluntary notifications not required by law, if we agree in advance.

Business income loss means:

1. the net profit before taxes you would have earned, or the net loss you would have avoided, but for the interruption; and
2. normal operating expenses, including payroll, that must continue during the interruption.

Forensic accounting fees to prove this loss are covered as described in Section III, part 1.8. It does not include profit you would have earned only because a widespread event harmed your competitors.

Claim means:

1. a written demand for money, services or other relief;
2. a lawsuit, arbitration or mediation;
3. a **regulatory proceeding**;
4. a written demand for **PCI fines and assessments**; or
5. a written request to pause (toll) a statute of limitations for a potential claim.

All **claims** arising from the same or **related** facts are one **claim**, made on the date the first one was made.

Claim expenses means reasonable attorneys' fees and other costs to investigate, defend, settle or appeal a **claim**, incurred by us, with our consent, or as Section V, part 2.2 allows, including appeal bond premiums. It does not include your own staff's salaries or overhead. **Claim expenses** reduce your limits.

Client accounts means:

1. accounts you hold for clients, such as trust or escrow accounts; and
2. a client's own bank or payment account that you are authorized in writing to operate or to start payments from, for example to run the client's payroll or pay its bills.

Cloud accounts means the accounts, tenants, user identities, settings and data that you control in an online service, such as your email, file-storage, online banking, payroll, accounting and tax-software accounts and your client portal. It covers only what you control, not the provider's own servers, code or network.

Computer fraud means someone's unauthorized entry into, or use of, your **computer systems** (including your **cloud accounts**) to:

1. transfer money or securities from your accounts or **client accounts** without your permission; or
2. alter a payment batch, payroll file, or payee or bank record held in your **computer systems**, which you then approve or release without knowing it was altered.

Computer replacement costs means the reasonable cost to replace computer hardware you own or lease with equivalent hardware, when a **security failure** has corrupted its firmware or software so that it no longer works as intended.

Computer systems means computers, servers, mobile devices, software, networks, storage, backup devices and connected devices (including Internet of Things devices) that are:

1. owned or leased by you, or operated by you, including your **cloud accounts**; or
2. personally owned by an **employee** or **executive** and used with your permission to access your systems or data.

It does not include **dependent systems**. If an attack on a **dependent provider's** systems gives someone unauthorized access to your **cloud accounts**, or damages, encrypts or exposes data in them, it is a **security failure** affecting your **computer systems** under every coverage. An interruption caused only because a **dependent provider's** service is unavailable to you, other than one caused by a **security failure** in your own **computer systems**, falls under Coverage E (or, for a **system failure**, Coverage P if purchased), not Coverage D.

Confidential business information means non-public business information of a third party in your care under a duty of confidentiality, such as a client's financial records.

Continuity date means the date shown in Item 8 of the Declarations.

Cyber extortion means a threat, made to obtain money, cryptocurrency, property or services from you, to:

1. release, sell or publish data in your care;
2. damage, encrypt, corrupt or disable your **computer systems** or **digital assets**, or continue doing so;
3. launch a denial-of-service attack against your **computer systems**; or
4. transfer funds from your accounts without permission.

It includes **ransomware** that has already encrypted or locked your systems.

Damages means judgments, awards and settlements you are legally obligated to pay, including pre- and post-judgment interest. Punitive or exemplary damages, and the multiplied part of any multiplied damages, are included only where the law shown in Item 11 of the Declarations allows them to be insured. **Damages** does not include:

1. fines, penalties or taxes, except **regulatory penalties** and **PCI fines and assessments** covered under Coverages J and K;
2. restitution, return of fees, or disgorgement of profits;
3. the cost of complying with an injunction or other non-monetary relief; or
4. amounts you owe only because you agreed to them in a contract, except: (a) amounts you would have owed anyway; (b) amounts you owe under a contract duty to keep **personal information** or **confidential business information** secure, or to pay for notifying people after a **privacy event**; and (c) **PCI fines and assessments** under Coverage K. We do not pay liquidated damages or service credits beyond what you would have owed without the contract.

Dependent provider means a business, other than an **insured**, that provides services you rely on to run your operations under a written or electronic agreement, including standard online terms you accepted. It does not include a provider of electricity, water, gas or other utilities, telecommunications, or **public internet infrastructure**.

Dependent systems means the computer systems a **dependent provider** operates, or has a hosting or cloud provider operate for it, to provide services to you, other than your **cloud accounts**.

Digital assets means your electronic data and software. It does not include computer hardware.

Discover means the first time an **executive**, or the security contact named in your **application**, becomes aware of facts that would lead a reasonable person to believe an **incident** has happened or is happening, even if its cause, scope or cost is not yet known.

Early warning means a notice to you, from a law enforcement or other government agency, your bank, your outside IT provider, a **dependent provider**, a security company monitoring your systems, or us, that your **computer systems** may have been compromised or that your credentials or data are being offered or used by criminals.

Employee means any past or present employee, including part-time, seasonal, temporary and leased workers, interns and volunteers, while working for you.

Executive means your owner, managing partner or managing member; any partner or member holding 10% or more of the **named insured**; your chief executive officer, chief financial officer and general counsel; and the **employee** you have designated as responsible for information technology or security. It does not include an outside IT provider.

Extortion expenses means the following. Item 1 always requires our prior written consent; items 2 and 3 need it only if you use a vendor outside our panel:

1. money, cryptocurrency or property paid to end **cyber extortion**, where lawful, and the cost of acquiring and transferring it;
2. fees of negotiators and other consultants to respond to the **cyber extortion**; and
3. the cost of screening payment recipients against sanctions lists, and of legal advice on whether a payment is lawful.

Extra expense means reasonable additional costs you incur to avoid or reduce **business income loss**, or to catch up on work the interruption delayed, such as renting equipment, paying overtime or temporary staff, hiring outside IT staff or moving work to other systems. It includes catch-up costs incurred up to 30 days after the **period of restoration** ends. Costs to avoid **business income loss** are covered up to the loss they avoid.

Financial institution means a bank, credit union, payroll or payment processor, broker-dealer or similar institution that holds or moves money or securities for you or your clients.

Funds transfer loss means money or securities taken from your accounts or **client accounts** resulting from **payment fraud** or **computer fraud**, and reasonable costs to try to recover them. For a client's own account, it includes only amounts you are legally obligated to repay the client, or repay with our consent, which we will not unreasonably withhold. It does not include personal funds of **employees** or **executives**, or chargebacks on payment cards used fraudulently. Wages or other amounts you must pay again because **payment fraud** diverted them are your loss, not an **employee's** personal funds.

Impersonation event (Coverage T only) means the publication or use, without your permission, of synthetic media (including deepfake audio or video), a lookalike website or internet domain, or a fake social media or messaging account, that falsely presents itself as you, or as an **executive** or **employee** speaking for you.

Impersonation response costs (Coverage T only) means reasonable costs, incurred with our consent within 90 days after you **discover** an **impersonation event**, for an expert to analyze whether content is fake; lawyers to ask platforms, registrars and hosts to remove the content, website, domain or account; public relations help; and warning your customers.

Incident means a **security failure**, **system failure**, **privacy event**, **cyber extortion**, **payment fraud**, **computer fraud**, **adverse publication** or, if purchased, an **impersonation event** (Coverage T) or **key customer event** (Coverage S). **Incidents** arising from the same or **related** facts are one **incident**, occurring when the first one occurred.

Incident response services means the following, provided through our 24/7 hotline for the first 7 days after you report an actual or suspected **incident**, up to the amounts in Item 4: consultation with a breach coach lawyer, initial forensic triage and containment guidance, and guidance on legal notice deadlines.

Insured, you and **your** mean:

1. the **named insured** and any company it owns more than 50% of;
2. **executives** and **employees**, while acting for you;
3. individual independent contractors, while working for you under your supervision; and
4. for Coverage I only, any person or organization you agreed in a written contract to add as an additional insured, but only for liability caused by your acts.

In Coverages A–H, M–P, S and T, "you" and "your" mean the **named insured** and its subsidiaries, except where a definition says otherwise.

Invoice manipulation loss means your direct net cost, excluding profit, of goods or services you delivered or will deliver, when a customer's payment to you is diverted because it paid a fraudulent invoice or followed fraudulent payment instructions sent as a result of a **security failure**. It does not matter whether you delivered before or after the diverted payment.

Key customer (Coverage S only) means a customer named for Coverage S in Item 6 that provided more than 10% of your revenue in the 12 months before the **policy period**.

Key customer event (Coverage S only) means an attack of the kind described in the definition of **security failure** on a **key customer's** own computer systems.

Malicious code means software designed to damage, disrupt, steal from or gain unauthorized access to computer systems, including viruses, worms, spyware and **ransomware**.

Media content means text, images, audio, video and other material, whether created by people or with artificial intelligence tools, that you publish on your websites, social media accounts, advertising or marketing. It does not include your products or software.

Media wrongful act means any of the following in your **media content**: defamation or disparagement; invasion of privacy or publicity rights; infringement of copyright, trademark, trade name or domain name (but not patents or trade secrets); or plagiarism.

Merchant services agreement means your agreement with a bank, payment processor or card brand that lets you accept payment cards.

Named insured means the organization shown in Item 1 of the Declarations.

Payment fraud means a deliberate deception by someone who is not an **insured**, by any means of communication (including email, text, messaging app, letter, phone or video call, and synthetic or deepfake audio or video), in which that person pretends to be, or to act for, you, an **executive**, **employee**, client, vendor, **financial institution** or other person you deal with, or falsely claims that genuine payment or bank details have changed, and that:

1. leads you, or a **financial institution** that holds your accounts or **client accounts**, to transfer money or securities, or to change payment or bank details that are then used for a transfer; and
2. causes a loss to you, or a loss you must make good to a client.

In this definition, "you" means the **named insured** acting through anyone authorized to make, approve or change its payments, including an **executive**, **employee**, individual independent contractor, or an **AI agent** acting within its authority.

PCI fines and assessments means fines, fraud recoveries, card reissuance costs and case management fees you owe under a **merchant services agreement** because of a **security failure** or **privacy event** involving payment card data. It does not include chargebacks or ordinary processing fees.

Period of restoration means the time that begins when an interruption of **computer systems** or **dependent systems** begins and ends when your operations are restored, or could have been restored with reasonable speed, to their level before the interruption, but no longer than 180 days. Reasonable speed never assumes that a ransom was paid.

Personal information means information about an identifiable individual that any law, in the United States or elsewhere, requires to be protected, in electronic or paper form, including Social Security, taxpayer identification, driver's license and passport numbers; financial account and payment card numbers; tax return information; health information; biometric data; and usernames and passwords.

Policy period means the period shown in Item 2 of the Declarations, ending earlier if the policy is cancelled.

Privacy event means:

1. unauthorized access to, or loss, theft or disclosure of, **personal information** or **confidential business information** in your care, in electronic or paper form, including while a **dependent provider** holds it for you;
2. your failure to give notice of a breach as a breach notification law requires; or
3. your failure to follow your own published privacy policy on protecting, sharing or giving people access to **personal information**.

It does not include **wrongful collection**.

Public internet infrastructure means the public domain name system (its root and top-level-domain servers), internet exchange points and internet backbone networks. It does not include a **dependent provider's** own systems, including the name servers it runs for its own services.

Ransomware means **malicious code** that encrypts or locks data or systems in order to demand payment.

Regulatory penalties means civil fines, penalties and consumer redress amounts imposed in a **regulatory proceeding**, where insurable under the law shown in Item 11 of the Declarations, or of the place where the **regulatory proceeding** is brought, whichever allows it. It does not include the cost of complying with orders or improving your security practices.

Regulatory proceeding means a request for information, civil investigative demand, investigation or civil proceeding, arising from a **security failure** or **privacy event**, by:

1. a U.S. federal, state or local government agency (such as the Federal Trade Commission, a state attorney general or the U.S. Department of Health and Human Services); or
2. a government agency or data protection authority outside the United States.

Related facts are facts that share a common cause or the same attacker's continuing access, or that form a causally connected series.

Reputational harm loss means the net profit before taxes you lose during the **reputational harm period** as a direct result of an **adverse publication**. It does not include the cost of repairing your reputation, which is covered as **breach response costs**.

Reputational harm period means the period shown in Item 6 of the Declarations (up to 90 days), beginning when the reputational harm waiting period shown there ends. The waiting period begins on the date of the first **adverse publication**.

Restoration costs means reasonable costs to restore, recreate or recollect **digital assets** to their condition before the **security failure** or **system failure**, from backups or original sources, and to remove **malicious code**, including the cost to determine that restoration is not possible. It does not include the value of the data itself, the cost of creating new data or software, or upgrades other than **security improvement costs**.

Retention means the dollar amount shown in Items 5 and 6 of the Declarations that you pay for each **incident** before we pay. Section III, part 1.3 explains how it works. For business interruption, the **waiting period** applies instead; for reputational harm, the reputational harm waiting period in Item 6 applies instead.

Retroactive date means the date shown in Item 8 of the Declarations. "Full prior acts" means there is no retroactive date.

Security failure means any of the following affecting your **computer systems**, including when caused by an **employee** or **executive** acting outside their authority or against your interests:

1. unauthorized access to or use of **computer systems**, including with stolen credentials or credentials obtained by deception;
2. infection by **malicious code**;
3. a denial-of-service attack;
4. loss or theft of a device containing your data; or
5. someone other than you causing an **AI agent** to exceed its authority in your **computer systems**, including through instructions hidden in content it processes.

For Coverage E, it means the same events affecting **dependent systems**.

Security improvement costs means reasonable costs, incurred within 90 days after you **discover** a covered **security failure**, of security measures our incident response team recommends in writing to prevent a similar **incident**, such as multi-factor authentication, endpoint detection and response, or improved backups. It includes the first year of any subscription.

Service fraud loss means charges from your cloud, hosting, artificial intelligence, utility or telephone providers for unauthorized use that the provider will not waive or reverse.

System failure means an unplanned and unintentional outage of **computer systems** not caused by a **security failure**. It includes one caused by human error, a programming error, a faulty software update or patch (including one released by a vendor), or an **AI agent** malfunctioning or exceeding its authority without anyone else causing it to. It does not include planned downtime, or a failure of electricity, water, gas or other utilities, telecommunications, satellites or **public internet infrastructure** that you do not operate (for Coverage P, that the **dependent provider** does not operate). For Coverage P, it means the same events affecting **dependent systems**.

Tracking technology means pixels, cookies, software development kits, session replay tools, chatbots and similar tools that collect information about visitors to your websites or apps.

Waiting period means the number of hours shown in Item 6 of the Declarations (or Item 7, if a security credit applies) that an interruption must last before business interruption coverage begins. We do not pay loss incurred during the **waiting period**.

We, us and **our** mean the insurer shown on the Declarations.

Wrongful collection means collecting, recording, sharing or using personal information through **tracking technology** without legally required notice or consent, including under wiretapping, eavesdropping or video privacy laws such as the California Invasion of Privacy Act.

Section III. Coverage details: how each coverage works

This section explains how limits, retentions and each coverage work in practice once an **incident** or **claim** happens.

1. Limits and retentions

- 1. How the limits work.** The policy aggregate limit in Item 4 of the Declarations is the most we will pay for all coverages combined, including **claim expenses**. Each limit in Item 6 is the most we will pay under that coverage for all **incidents** and **claims** in the **policy period** combined, and is part of the aggregate limit, not in addition to it, unless Item 6 says "in addition". A limit marked "applies across coverages" is the most we will pay for that kind of loss under all coverages combined, whichever coverage the loss falls under. The system failure limit is such a limit: it caps **business income loss**, **extra expense** and **restoration costs** caused by a **system failure** under Coverages D and F combined. It does not reduce Coverage P, which has its own limit.
- 2. Services outside the aggregate.** Coverage A and pre-incident assistance (Section V, part 2.3) are provided in addition to the aggregate limit, up to the amounts in Item 4, and no **retention** applies to them.
- 3. One retention per incident.** One dollar **retention** applies to each **incident** and every **claim** arising from it, even if they trigger several coverages or fall in different policy periods: the largest that applies. The **waiting period** applies to business interruption, and the reputational harm waiting period in Item 6 to reputational harm, instead of a dollar **retention**. **Claim expenses** count toward the **retention**, and so do payments by other insurance or by others on your behalf. If you earn the reduced Coverage H **retention**, it is the only dollar **retention** for the Coverage H loss, and what you pay toward it counts toward any other **retention** for the same **incident**.
- 4. Settling within your retention.** You may settle a **claim** yourself if the total cost, including **claim expenses**, stays within your **retention** and you obtain a full release from every claimant.
- 5. Security credits.** The credits in Item 7 apply to every **incident** you **discover** while the verified control is in place for substantially all the users, devices and accounts it covers. Exceptions you disclosed in your **application** never count against you. If you stop using a verified control, tell us within 30 days. The credit stops for **incidents** you **discover** after you stopped, and resumes when you restore the control. A control disabled by the attacker during the **incident** itself does not lose the credit.
- 6. Ransomware coinsurance.** If your backups were not verified when the **incident** happened, you pay 20% of the **restoration costs**, **business income loss** and **extra expense** under Coverages D and F that result from **ransomware** encrypting or locking your **computer systems**, after the **retention**. We pay the other 80%, up to the applicable limit. This coinsurance applies across Coverages D and F. It does not apply to **extortion expenses**, **breach response costs** or liability coverages. Backups are verified if you successfully tested restoring from them within the 12 months before the **incident** and kept a copy that is offline or immutable. If you restore the affected **digital assets** from your own backups anyway, this coinsurance does not apply to that **incident**.
- 7. Known-exploited vulnerabilities.** This rule applies only to a vulnerability on the U.S. Cybersecurity and Infrastructure Security Agency's Known Exploited Vulnerabilities catalog that we described in writing to your main contact and your security contact, naming the affected system. If, more than 45 days after our notice, you have neither patched it nor applied the vendor's or the agency's published mitigation, and an attacker then uses it in an **incident**, you pay 20% of the loss from that **incident**, after the **retention**. This applies even if our pre-issue scan showed the vulnerability. If both this rule and part 6 apply to the same loss, you pay 20% in total, not 40%. This is the only way patching affects your coverage.

8. **Proof-of-loss help.** We pay up to \$50,000 per **incident** for an independent forensic accountant to help you prove any loss under the coverages for your own losses. This reduces the aggregate limit but not the limit of the coverage it supports.
9. **How your security can affect what we pay.** Only three terms can reduce what we pay because of your security practices: the ransomware coinsurance (part 1.6), the known-exploited-vulnerability coinsurance (part 1.7) and the lower Coverage H limit (part 6.2 of this Section). Each applies only if we show that the missing control or procedure caused the **incident** or made the loss larger. If we show that, the term applies as its part describes. No exclusion or condition reduces what we pay because of your security practices. Separately, your **retention, waiting period** and claim-free reduction depend on the security credits and conditions in part 1.5 and Section V, part 6. They are part of your price. What you told us in your **application** is dealt with in Section V, part 3.

2. Incident response and breach response (Coverages A and B)

1. Call our 24/7 hotline, or use any channel in Item 10, as soon as you suspect an **incident**. A breach coach lawyer will guide the response.
2. Where possible, forensic experts are hired through the breach coach, so their work stays protected by legal privilege.
3. Vendors on our panel are pre-approved. You may use another vendor with our consent, which we will not unreasonably withhold, at rates similar to our panel's.
4. **Breach response costs** must be incurred within 12 months after you **discover** the **incident**.
5. **You decide on legally required notices.** You may notify individuals, regulators and law enforcement as the law requires without waiting for our consent, and we will pay the reasonable costs under Coverage B.

3. Cyber extortion and ransomware (Coverage C)

Paying is never required. Whether to pay is your decision, made with our consent under the steps below. You never have to pay a ransom to keep any other coverage. We will not reduce what we pay under any coverage because you chose not to pay, even if paying might have shortened the outage.

Before any extortion payment:

1. **Contact us.** We will arrange an experienced negotiator.
2. **Assess the threat together.** We and you will consider whether the threat is credible and whether you can restore from backups instead of paying.
3. **Report the attack.** Before we consent to a payment, the attack must be reported to the FBI (through its Internet Crime Complaint Center) or to the U.S. Cybersecurity and Infrastructure Security Agency, unless law enforcement advises otherwise. Our breach coach will make the report for you if you ask.
4. **Check that payment is lawful.** We will pay for sanctions screening and a lawyer's advice on whether a payment is lawful. We will not pay, and you must not pay, anyone that sanctions laws prohibit paying.
5. **Get our written consent.** We will not unreasonably withhold consent to a lawful payment. We may make the payment directly.

Laws about paying. If a law requires you to notify a government agency before or after an extortion payment, to wait for permission, or to explain a payment afterwards, you may do so without our consent, and we will pay the reasonable legal cost under Coverage C. A delay the law requires is not a breach of this policy. If a law forbids the payment, we

will not pay it, but Coverage C still pays negotiation, investigation and advice costs. Payments in cryptocurrency are valued on the date paid.

4. Business interruption (Coverages D, E and P)

1. **How we calculate your loss.** We look at your net profit and operating expenses over the 12 months before the interruption, adjusted for trends, seasonality (such as a retailer's holiday season or an accounting firm's tax season) and the business you would likely have had.
2. **Shutting down to limit damage.** If you shut down or disconnect **computer systems**, or your connection to **dependent systems**, to contain an actual or reasonably suspected **security failure** (in your systems or at a **dependent provider**), the resulting interruption is treated as caused by that **security failure**, under Coverage D or E as the case may be. This applies if you act on the advice of our incident response team, a government agency or a **dependent provider**, or in your own reasonable judgment. If the suspected **security failure** did not happen, we cover up to 72 hours of the interruption.
3. **Waiting periods.** The **waiting period** starts when the interruption begins. Item 6 shows it for each coverage, and Item 7 shows any reduction you earned.
4. **Dependent providers do not need to be named.** Coverages E and P apply to any **dependent provider** that serves you under a written or electronic agreement.
5. **Proof of loss.** Send us a signed proof of loss within 120 days after the **period of restoration** ends. We will extend this deadline on request if you need more time. Forensic accounting fees to prepare it are covered as described in part 1.8.
6. **Getting back to business.** You must take reasonable steps to resume operations. Reasonable steps do not include paying a ransom or other extortion payment. We may review the records that relate to your loss for up to 12 months after receiving your proof of loss.

5. Data restoration and security improvements (Coverages F and G)

1. We restore **digital assets** from backups or original sources to their condition before the **security failure** or **system failure**. If they cannot be restored, we pay the reasonable cost of establishing that.
2. If the same software or equipment is no longer available, we pay for the closest current equivalent.
3. Coverage G is the only way this policy pays for upgrades. Our incident response team must recommend the upgrade in writing, and you must make it within 90 days after you **discover** the **security failure**. We pay the first year of any subscription, not later renewals.

6. Fraud (Coverages H and R)

1. **Verification procedure.** The full Coverage H limit in Item 6 applies if, when the loss happened, you had a written procedure requiring whoever receives a request to confirm it before acting. The confirmation must use a phone number from your own records (never one supplied in the request) or another channel set up in advance. The procedure must cover: (a) any request to add or change the bank or payment details of a vendor, client, **employee** or client's employee; and (b) any request to transfer more than \$5,000 received by email, text, messaging app, phone or video call.
2. **When the lower limit applies.** The \$100,000 limit in Item 7 applies only if you did not have that procedure, or had not trained the people who acted on the request, and part 1.9 of this Section is met. It never applies to **computer fraud**, to **invoice manipulation loss**, or to **payment fraud** in which the party deceived was a **financial**

institution. If you had the procedure and trained your people, a failure to follow it, by one person or several on the same request, does not reduce your limit. A request sent from, or through, a compromised mailbox or account is still **payment fraud** for this part.

3. **Act fast.** Tell your bank and report the fraud to the FBI's Internet Crime Complaint Center as soon as possible, ideally within 24 hours. Our funds-recovery team will help. Reporting to us within 72 hours of **discovery** earns the reduced **retention** in Item 6.
4. **Keep your rights against the bank.** Under the law on funds transfers, a bank must sometimes refund an unauthorized or fraudulent transfer. Tell your bank in writing about any such transfer as soon as you can, and within the time your account agreement and the law allow. We will not wait for the bank's decision before paying covered loss. After we pay, we may pursue the bank in your name under Section V, part 10.
5. **Recoveries.** Money recovered after we pay goes first to reimburse your **retention** and any uninsured loss, then to us.
6. **Invoice fraud.** We pay **invoice manipulation loss** once you show that the customer paid the fraudulent account and you have made reasonable efforts to collect.

7. Liability claims (Coverages I, J, K, L and Q)

1. **Defense.** We have the right and duty to defend any covered **claim**, even if the allegations are groundless. You may choose defense counsel from our panel, or other counsel we agree to at similar rates.
2. **Settlement.** We will not settle a **claim** without your consent. You may refuse a settlement we recommend that the claimant would accept. If you do, we pay the settlement amount and the **claim expenses** incurred up to your refusal, and 70% of further **damages** and **claim expenses**. You pay the rest.
3. **Defense costs reduce your limits.** Our duty to defend ends when the applicable limit is used up.
4. **Mixed claims.** If a **claim** includes both covered and uncovered allegations, we pay 100% of **claim expenses** until the covered allegations are resolved, and we allocate **damages** fairly between covered and uncovered matters.
5. **Penalties and punitive damages.** We pay **regulatory penalties** only where insurable under the law that applies, and punitive damages only as the definition of **damages** allows.

8. Bricking, reputational harm and cryptojacking (Coverages M, N and O)

1. **Computer replacement (M).** We pay to replace hardware with equivalent hardware when replacement costs no more than repair.
2. **Reputational harm (N).** After the reputational harm waiting period in Item 6, we calculate **reputational harm loss** the same way as **business income loss**, excluding any loss already paid under Coverages D, E or P.
3. **Cryptojacking and telecom fraud (O).** This includes extra cloud, artificial intelligence service, utility and telephone charges. You must first ask your provider to waive or reverse the unauthorized charges; we pay what the provider will not.

Section IV. Exclusions: what we don't cover

This policy does not cover loss, **claims** or costs arising from the matters listed in part 2. Each exclusion applies only as written. Where an exclusion says it does not apply to something, that exclusion does not remove coverage for it; whether it is covered still depends on the insuring agreements, definitions and other terms of this policy.

1. What this policy does not exclude

Many cyber policies deny claims for the reasons below. This one does not. This part is policy wording, not a summary.

- **Security lapses.** We do not exclude loss because you failed to patch software, encrypt a device or maintain a security control. Your security affects your price and credits, not whether you are covered. Only three disclosed terms can reduce what we pay because of your security practices (the ransomware coinsurance, the known-exploited-vulnerability coinsurance and the lower fraud limit), and each applies only if the gap mattered to the loss (Section III, part 1.9). Losing a security credit can raise your **retention** (Section III, part 1.5).
- **Honest application mistakes.** An unintentional error on your **application** does not void this policy (Section V, part 3).
- **Rogue insiders.** Attacks by **employees** or **executives** acting against your interests are covered for you. Exclusion 4 applies to the insider personally, and to you only as it says.
- **Artificial intelligence. Incidents** caused or carried out with artificial intelligence, including deepfakes and hijacked **AI agents**, are covered like any other. So are **media content** claims about material created with AI tools.
- **Cyber terrorism and state-linked criminals.** Only war and major state-backed cyber operations are excluded (exclusion 15).
- **Choosing not to pay a ransom.** It never reduces what we pay (Section III, part 3).

2. Exclusions

1. **Bodily injury and property damage.** Physical injury, sickness or death, or physical damage to tangible property. This does not apply to emotional distress claims under Coverages I and L, or to Coverage M.
2. **Known problems.** Any **incident, claim** or circumstance that an **executive** knew about before the **continuity date** and that a reasonable person in that role would have expected to lead to a **claim** or loss, or that you reported under an earlier policy that covers it. A circumstance does not include: (a) a vulnerability, missing patch or other security weakness that, as far as any **executive** knew, had not been exploited; (b) anything disclosed in your **application**, unless the Declarations or an endorsement exclude it; or (c) an **early warning** that an investigation completed before the **continuity date** found was not an **incident**.
3. **Before the retroactive date.** Any **incident** or **media wrongful act** that first happened before the **retroactive date**.
4. **Intentional wrongdoing by executives.** Any deliberately dishonest, fraudulent or malicious act, or knowing violation of law, by an **executive**, or by anyone acting with an **executive's** knowledge and consent. This exclusion applies only after a final, non-appealable ruling in the matter or in a separate proceeding, or the person's written admission, establishes the act. Until then we defend **claims** and pay covered loss under every coverage. It does not apply to any **insured** who did not take part in or know about the act. For the **named insured**, it applies only if its owner, managing partner or managing member, chief financial officer or general counsel took part in the act, or knew about it and let it continue.

5. **Contract promises.** Liability you took on under a contract. This does not apply to amounts covered under item 4 of the definition of **damages**, or to liability you would have had without the contract.
6. **Claims between insureds.** A **claim** by one **insured** against another, or by a company that owns more than 20% of you or that you own more than 20% of. This does not apply to a **claim** by any individual **insured** about their own **personal information**, or to a **claim** by an additional insured.
7. **Employment practices.** Wrongful termination, discrimination, harassment or other employment-related claims, except an **employee's claim** arising from a **security failure** or **privacy event**.
8. **Securities, antitrust, benefits and racketeering laws.** Violations of securities, antitrust, employee-benefits (ERISA) or racketeering (RICO) laws, or unfair or deceptive trade practices. The last part does not apply to a **regulatory proceeding** arising from a **security failure** or **privacy event**, or to a **claim** under Coverage I or Q arising from a **security failure**, **privacy event** or **wrongful collection**.
9. **Unsolicited communications.** Violations of laws restricting calls, texts, faxes or emails, such as the Telephone Consumer Protection Act or the CAN-SPAM Act. This does not apply if a **security failure** caused the communications.
10. **Wrongful collection and biometric laws.** **Wrongful collection**, except under optional Coverage Q; or violations of the Illinois Biometric Information Privacy Act or similar laws governing how biometric data is collected, kept or used. This does not apply to **breach response costs**, or to liability arising from a **security failure** that exposes biometric data.
11. **Patents and trade secrets.** Infringement of patents or misappropriation of trade secrets. Other intellectual property claims are covered only under Coverage L.
12. **Infrastructure failures.** Failure or interruption of electricity, water, gas or other utilities, telecommunications, satellites or **public internet infrastructure** that you do not operate, whatever the cause. This does not apply to loss from a **security failure** affecting your **computer systems**, or, under Coverages E and P, to a **security failure** or **system failure** within a **dependent provider's** own systems.
13. **Natural disasters and physical events.** Fire, flood, earthquake, windstorm, explosion or other natural or physical catastrophe. This does not apply to theft or loss of a device, or to physical access used to carry out a **security failure**.
14. **Government orders.** Seizure, confiscation or destruction of your systems or data by order of a government authority, or an order to shut down your systems. This does not apply to a **regulatory proceeding**, or to a law enforcement request to preserve or hand over evidence about a covered **incident**.
15. **War and state-backed cyber operations.**
 1. **What is excluded:** (a) war, including a cyber operation carried out as part of a war; or (b) a state-backed cyber operation that has a major detrimental impact on the functioning of another state, because of its effect on that state's security or defense or on the availability, integrity or delivery of its essential services. War means the use of physical force by one state against another, or civil war, rebellion, revolution, insurrection or military takeover, whether or not war is declared. A state-backed cyber operation is one carried out by, at the direction of, or under the control of a state. Essential services include financial, health, utility, emergency, food, energy and transportation services. In this exclusion, "state" means a sovereign country, and "government" means its national government. It never means a U.S. state.
 2. **Bystanders stay covered.** Part (b) does not apply to your **computer systems**, or a **dependent provider's** systems, located outside the country that suffered the major detrimental impact. Your **cloud accounts** are treated as located at your address in Item 1.

3. **Cyber terrorism and state-linked crime stay covered.** Attacks by non-state groups for political, religious or ideological goals, and ransomware, espionage or fraud by groups linked to a state, are not excluded unless (a) or (b) applies.
4. **How attribution works.** We will rely on attribution by the national government of the country where your affected **computer systems** (for Coverage E, the affected **dependent systems**) are located. Until that government attributes the operation, we may rely on other objectively reasonable evidence, which we will share with you. **We bear the burden of proving this exclusion applies.**
5. **We keep helping while attribution is pending.** Coverage A, **breach response costs** and defense of **claims** continue until we establish that this exclusion applies. We will not seek repayment of amounts already paid.
16. **Nuclear and pollution.** Nuclear reaction, radiation or radioactive contamination, or the release of pollutants.
17. **Prohibited payments.** Any payment that trade or economic sanctions laws prohibit us from making, including reimbursing you for a payment you made to a person those laws prohibit paying.
18. **Investment losses.** Changes in the value of securities, cryptocurrency or other assets, or trading losses. This does not apply to **funds transfer loss** or **extortion expenses**.
19. **Profits you weren't entitled to.** Any profit or advantage you were not legally entitled to, once a final, non-appealable ruling or the person's written admission establishes it. Until then we will defend the **claim**.

Section V. Conditions: the rules both sides follow

These conditions apply to every coverage. Parts 7, 8 and 12 set out commitments we make to you.

1. Reporting incidents and claims

1. Tell us through any channel in Item 10 of the Declarations as soon as practicable after you **discover** an **incident** or a **claim** is made against you.
2. **Deadline for claims.** You must report a **claim** no later than 90 days after the **policy period** ends. For a **claim** first made during an optional extended reporting period, the deadline is 60 days after that period ends. These deadlines are firm, except as part 1.4 says.
3. **Late notice of incidents.** If you report an **incident** late, we will reduce what we pay only to the extent the delay actually harmed our ability to respond to it.
4. **Reports lock in coverage.** If, during the **policy period** or within 90 days after it ends, you report an **incident** you **discovered** during the **policy period**, or facts you learned of during the **policy period** that could reasonably lead to a **claim**, every later **claim** arising from it, or from the same or **related** facts, is treated as first made and reported on the date you reported, or on the last day of the **policy period** if you reported after it ended. It is covered only under this policy, whenever it is actually made. You do not need to say who might sue. Send us each such **claim** as soon as practicable after it is made; the deadline in part 1.2 does not apply to it.
5. **Legal deadlines come first.** Nothing in this policy requires you to delay a notice, filing or report to affected individuals, regulators or law enforcement that you reasonably believe the law requires.

2. Working together

1. You will cooperate with us, give us the information we reasonably need, and give our forensic team access to affected systems.
2. **Consent.** Do not admit liability or settle a **claim** without our consent. You never need our consent to use vendors on our panel; to make notices, filings or reports the law requires; to take reasonable steps to contain an attack in the first 72 hours; or to settle within your **retention**. If you incur other costs without our consent, we will reimburse reasonable and necessary costs that are otherwise covered, unless the lack of consent actually harmed us. Complying with a breach notification law is not an admission of liability.
3. **Pre-incident assistance.** If you have a security question before anything is suspected and before any **early warning** (such as whether an email is phishing, or whether a vendor's security terms are adequate), we will provide up to \$2,500 per **policy period** of legal or forensic advice. This is in addition to the aggregate limit, has no **retention**, and is not treated as a **claim**.

3. Your application

1. We issued this policy relying on your **application**.
2. **Honest mistakes do not void your policy.** We will not rescind this policy, add exclusions, reduce limits or deny coverage because of an unintentional error or omission in your **application**. Only answers to questions we asked in the **application** can count as an error or omission. If an answer was inaccurate, we may change only the premium,

the **retention** and the security credits in Item 7 to what they would have been had we known the correct answer. If we would not have issued this policy at all, it still continues until the end of the **policy period**, and we may choose not to renew it (part 5.3).

3. **Rescission only for deliberate misstatements.** We may rescind this policy only if an **executive** knowingly and intentionally made a material misstatement in the **application**. A rescission applies only to the **named insured** and to **insureds** who made or knew about the misstatement. One **insured's** knowledge is not imputed to any other **insured**, except that an **executive's** knowledge is imputed to the **named insured**.
4. **What our scan saw, we accept.** We will not deny or reduce coverage, or claim misrepresentation, because of any condition our pre-issue security scan showed, except as Section III, part 1.7 allows after our written notice.

4. Changes during the policy period

1. **New companies.** A company you acquire is automatically covered if its revenue is less than 25% of yours. Larger acquisitions are covered for 90 days; tell us within that time, and we may adjust the premium to keep covering them.
2. **If you are acquired.** If another organization acquires or merges with the **named insured**, this policy continues until the end of the **policy period**, but only for **incidents, media wrongful acts** and **wrongful collection** before the change. You may buy an extended reporting period.
3. **Security changes.** Tell us within 30 days if you stop using a verified control shown in Item 7 (Section III, part 1.5).

5. Cancellation, non-renewal and extended reporting

1. **You may cancel at any time.** We will refund the unused premium pro rata.
2. **We may cancel only** for non-payment of premium, on 10 days' written notice stating the reason, or because you knowingly made a false statement in your **application**, on 45 days' written notice. An honest mistake is never a reason to cancel (part 3.2). We will send any notice by first-class mail to the address in Item 1, and give longer notice if state law requires.
3. **Non-renewal and renewal changes.** We will give at least 60 days' written notice if we will not renew. If we offer to renew with a higher premium or reduced coverage, we will send you by first-class mail, at least 45 days before this policy ends, the renewal terms, the premium due, each change and the reasons for it.
4. **Automatic extended reporting.** If this policy is cancelled or not renewed, then for 60 days after it ends, **claims** first made against you during those 60 days, arising from **incidents, media wrongful acts** or **wrongful collection** that first happened before this policy ended, are treated as made on the last day of the **policy period**. This does not apply to a **claim** covered by other cyber insurance you buy to replace this policy.
5. **Optional extended reporting.** If either of us cancels or does not renew this policy, for any reason other than non-payment or a knowingly false statement in your **application**, you may buy an extended reporting period of 12 months for 75% of the annual premium, or 24 months for 125%. Tell us within 60 days after the policy ends. Any extended reporting period is part of the aggregate limit, not in addition to it.

6. Renewal benefits

1. **Claim-free retention reduction.** For each consecutive claim-free year you renew with us, your dollar **retention** drops by 25% of the **retention** then in effect, to a minimum of \$2,500. To keep it, keep your security contacts current with us and fix any critical issue we report to you within 30 days, or on a timeline we agree in writing. A claim-free year is a policy year in which we paid nothing beyond your **retention**, apart from Coverage A, pre-

incident assistance, and the cost of investigating an **early warning** or suspected **incident** that turned out not to be an **incident**. A critical issue is a vulnerability on the Known Exploited Vulnerabilities catalog, or one our scan rates critical, that we describe to you in writing.

2. **Calling early never counts against you.** Use of Coverage A or pre-incident assistance, including an **early warning** investigation that finds nothing, is not treated as a **claim** for this benefit or when we price your renewal.

7. Our service standards

1. **24/7 response.** Our hotline is answered around the clock, and we aim to have a member of our incident response team contact you within one hour of your report.
2. **Decisions.** We aim to give you a written coverage position, citing the policy wording we rely on, within 30 days after receiving the documents we ask for.
3. **Payment.** We will pay undisputed amounts within 15 days after we agree on them. If we pay later, we add interest at 8% a year, compounded annually, from the day payment was due. This interest is in addition to any remedy the law gives you.
4. **Cash advance for business interruption.** Once we confirm that Coverage D, E or P applies, we will advance 50% of our reasonable estimate of your loss to date, up to 25% of the policy aggregate limit or the limit of the coverage that applies, whichever is lower, within 10 business days, and update the advance as the loss develops.
5. **One accountant, one number.** You may choose a single forensic accountant from our panel to measure your business interruption loss for both of us.

8. Resolving disagreements

1. **Free internal review.** If you disagree with a coverage decision, you may ask for review by a claims professional who was not involved in it. We will respond within 30 days.
2. **Mediation.** If we still disagree, either of us may ask for non-binding mediation. We will pay the mediator's fees.
3. **Court or arbitration.** After that, either of us may go to court in the state shown in Item 11 of the Declarations. You may choose arbitration instead, binding where state law allows.

9. Other insurance

1. Coverages A and B apply first, before any other insurance. Coverage H applies in excess of any crime or fidelity insurance you have. All other coverages apply in excess of other valid insurance, unless that insurance is written specifically to sit above this policy.
2. **Professional liability insurance.** If a **claim** arising from a **security failure** or **privacy event** could also be covered by your professional liability (errors and omissions) insurance, Coverage I responds as if that other insurance did not exist. We will not refuse or delay your defense because of it, and we will seek any contribution directly from the other insurer.

10. Recoveries and subrogation

1. After we pay, we take over your rights to recover the payment from others, including your bank, and you will help us pursue them. You may waive those rights in a written contract signed before the **incident**.
2. Money recovered, after the costs of recovering it, goes first to reimburse your **retention** and any uninsured loss, then to us.

11. General terms

1. **Territory.** This policy covers **incidents** anywhere in the world and **claims** brought anywhere in the world, where legally permitted.
2. **The named insured acts for everyone.** The **named insured** gives and receives notices, pays premium and receives refunds for all **insureds**.
3. **Assignment.** This policy cannot be assigned without our written consent.
4. **Bankruptcy.** Your bankruptcy or insolvency does not relieve us of our obligations.
5. **State law.** If any term conflicts with the law of the state where this policy is issued, it is amended to meet that law's minimum requirements.
6. **Summaries and headings.** Headings, the "plain English" column in Item 6, the cover page, the "What's inside" table and the "If something happens" page are for convenience and do not change coverage. Everything else in the Declarations and Sections I to V, including Section IV, part 1, is policy wording.
7. **Liberalization.** If we broaden this policy form for new policies during your **policy period** without charging more, you automatically get the broader terms.
8. **Entire agreement.** The Declarations, **application**, this policy form and any endorsements make up the entire contract. All amounts are in U.S. dollars.

12. Security services we offer

We may offer you security tools and services, such as vulnerability alerts, phishing training or email security, free or at a reduced cost. They are not part of this policy's coverage, and we offer them on the same terms to every policyholder in the same risk class. Using them, choosing not to use them, or any failure of them is never a reason for us to deny or reduce payment under this policy, except under Section III, part 1.7 when we have sent the written notice it describes.

If something happens: six steps

1. **Call the hotline first** ((303) 555-0142). Our breach coach answers 24/7, and the first 7 days of expert help cost you nothing.
2. **Don't pay a ransom, negotiate or admit fault** before talking to us. You never have to pay a ransom to keep your coverage.
3. **Preserve evidence.** Don't wipe or rebuild systems until our forensics team says so.
4. **Money sent to a fraudster? Call your bank at once**, then us. The first 24 hours matter most for getting it back.
5. **We assemble your response team** of lawyers, forensic experts and negotiators from our panel.
6. **Make legally required notices on time.** You never need our permission to meet a legal deadline.